

MIGUEL ANGEL SALAZAR MARTINEZ

Universidad Politécnica de San Luis Potosi

CNO 4 – Seguridad Informática

Profesor: Servando López Contreras

Actividad 7 – File Path Traversal Traversal
sequences blocked with absolute path bypass

22/09/26

Introducción

En el laboratorio anterior logramos leer el archivo `../../../../etc/passwd` exitosamente, pero eso fue en un escenario "ideal" donde no había defensas. En el mundo real, los desarrolladores ya conocen el peligro del Path Traversal e intentan bloquearlo filtrando la secuencia `../`. Sin embargo, la seguridad es un juego de ataque y defensa: filtrar una sola cadena de texto no es suficiente. Un atacante puede usar la ruta absoluta como una técnica simple pero efectiva para saltarse el filtro y acceder directamente al archivo objetivo.

La lección clave de este laboratorio es: la defensa debe ser sistémica, no fragmentada. Si el desarrollador solo bloquea `../` pero olvida que la ruta absoluta también es peligrosa, esa "defensa" es inútil. Entender esta técnica de bypass nos ayuda a diseñar mecanismos de seguridad más completos, que no solo bloqueen patrones de ataque conocidos, sino que partan del principio fundamental de que toda entrada del usuario es potencialmente maliciosa.

Marco Teórico

El error común en la defensa contra Path Traversal

Muchos desarrolladores, al ser conscientes del riesgo, añaden un filtro simple que detecta y rechaza cualquier entrada que contenga `../`. La lógica es: "si el atacante necesita 'subir' con rutas relativas, bloqueo el 'subir'". Sin embargo, esta defensa tiene un punto ciego fundamental: la ruta absoluta.

La naturaleza y peligro de la ruta absoluta

En sistemas Linux/Unix, una ruta que comienza con `/` se considera absoluta, y localiza el archivo directamente desde la raíz del sistema de archivos. Cuando la aplicación pasa la entrada del usuario directamente a la API del sistema de archivos, si se le pasa `/etc/passwd`, el sistema lo interpreta como "desde la raíz, busca el directorio `etc` y el archivo `passwd`", sin pasar por el directorio de trabajo que la aplicación tenía previsto. Esto significa que aunque la aplicación "espera" que el archivo esté en `/var/www/images/`, la ruta absoluta hace que esa expectativa sea irrelevante.

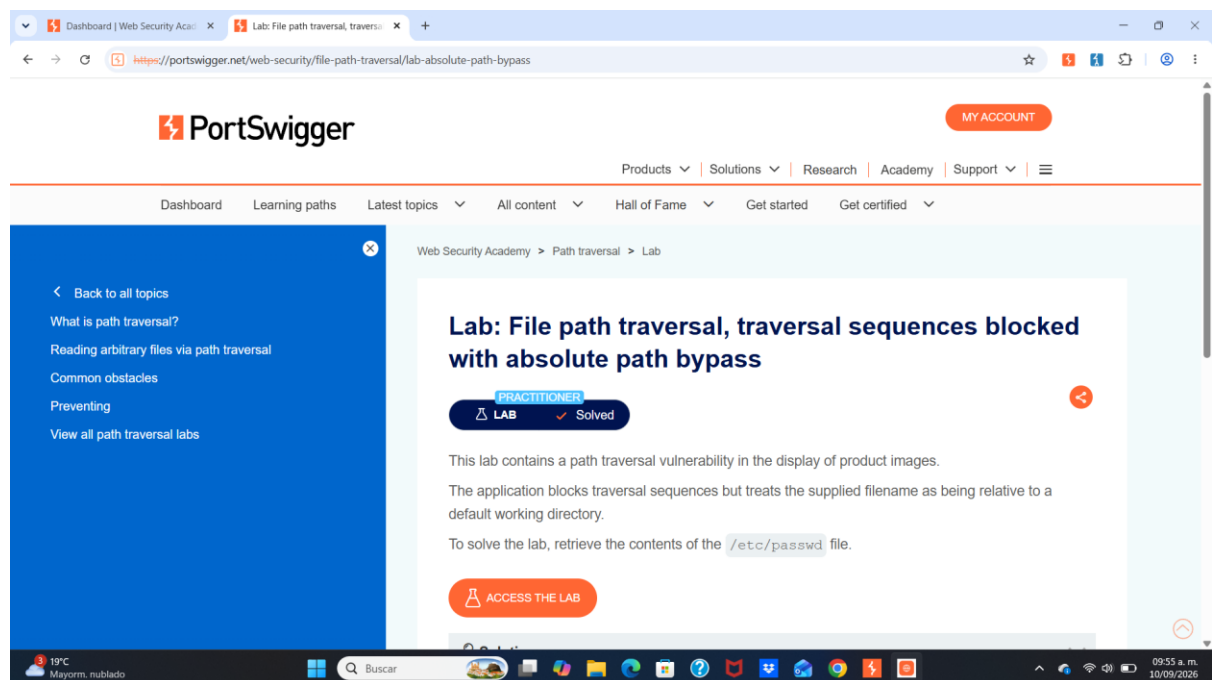
Diferencia entre ruta relativa y absoluta

El detalle técnico clave es: cuando la aplicación establece un "directorio de trabajo" (como `/var/www/images/`), espera que el nombre de archivo proporcionado por el usuario sea relativo a ese directorio. Por ejemplo, `filename=robot.jpg` se resuelve como `/var/www/images/robot.jpg`. Pero si el usuario proporciona una ruta absoluta (comenzando con `/`), el sistema operativo ignora el contexto del directorio de trabajo y usa esa ruta absoluta directamente. Este es el núcleo del bypass: el filtro solo verificó la cadena `../`, pero no verificó si la ruta comenzaba con `/`.

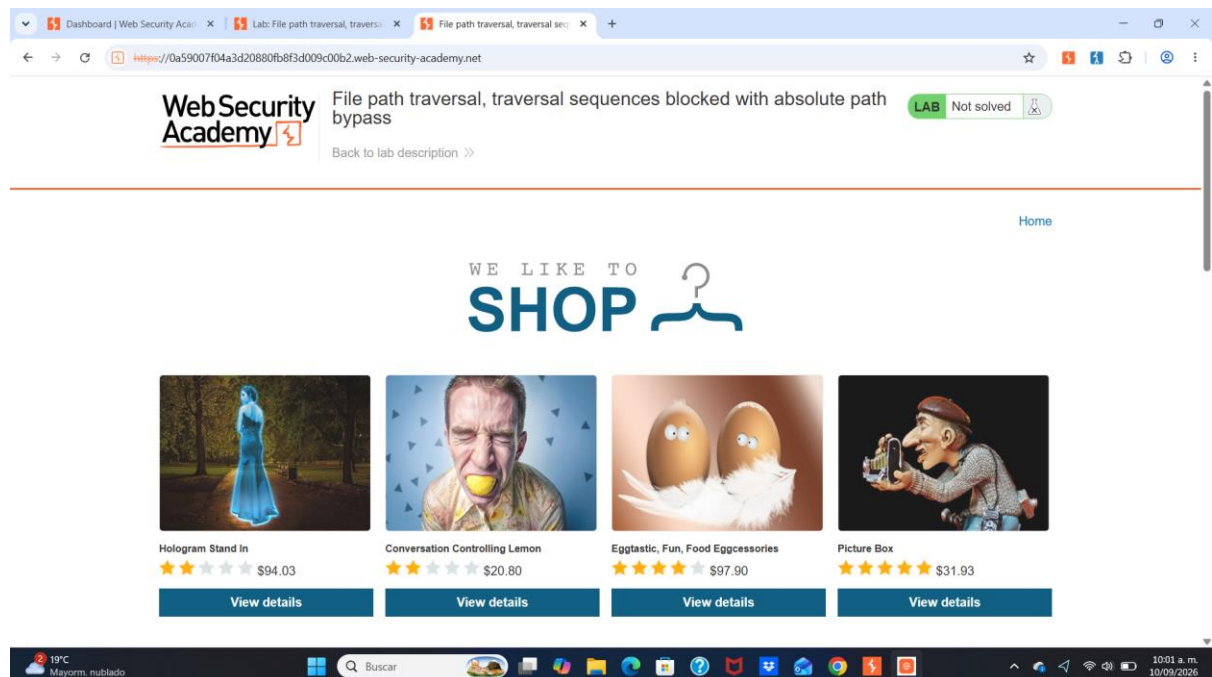
La lección para la defensa

La defensa correcta requiere normalizar la ruta y validar el prefijo: primero resolver la entrada del usuario en una ruta absoluta canónica, y luego verificar si esa ruta está realmente dentro del directorio seguro esperado. Si la ruta resuelta no comienza con el directorio seguro, se rechaza la petición.

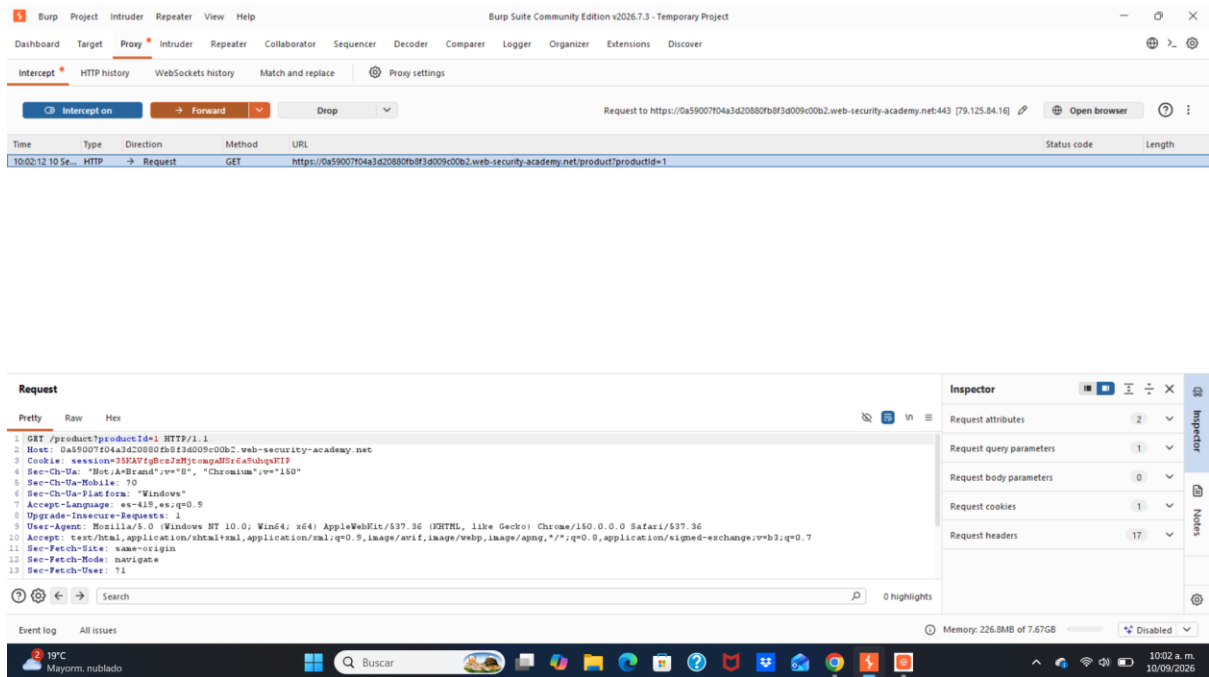
Desarrollo



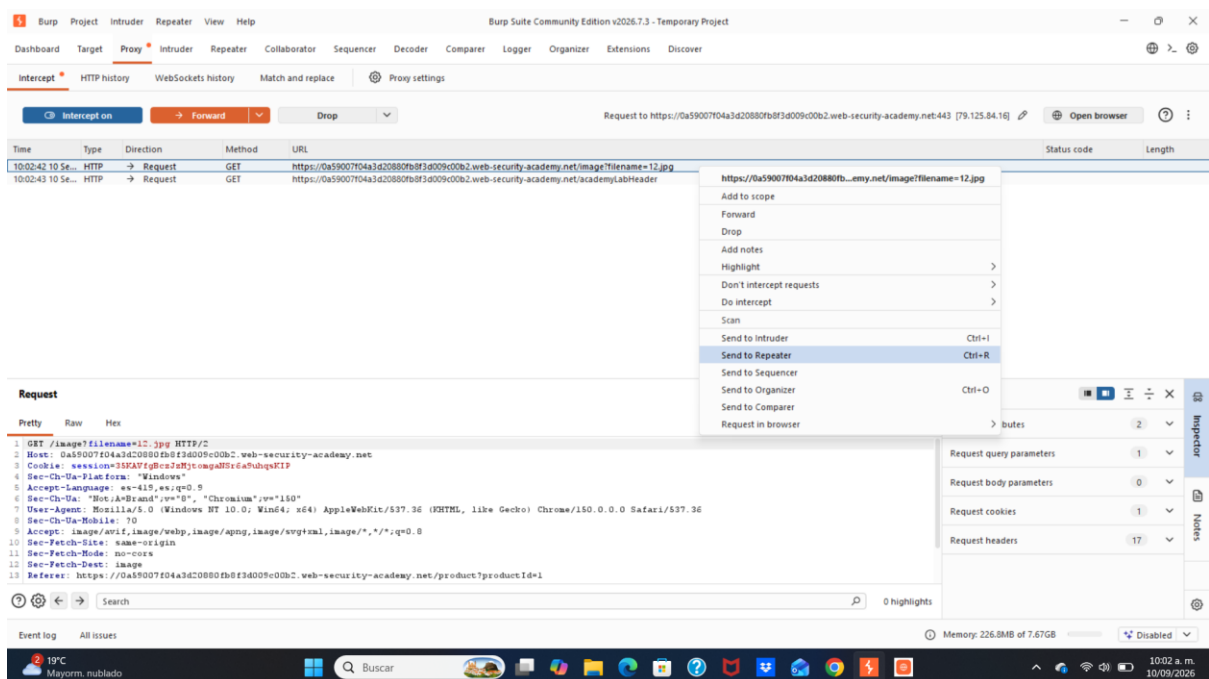
En nuestro PortSwigger abriremos la actividad Traversal sequences blocked with absolute path bypass, que es una variante a esta tan famos vulnerabilidad.



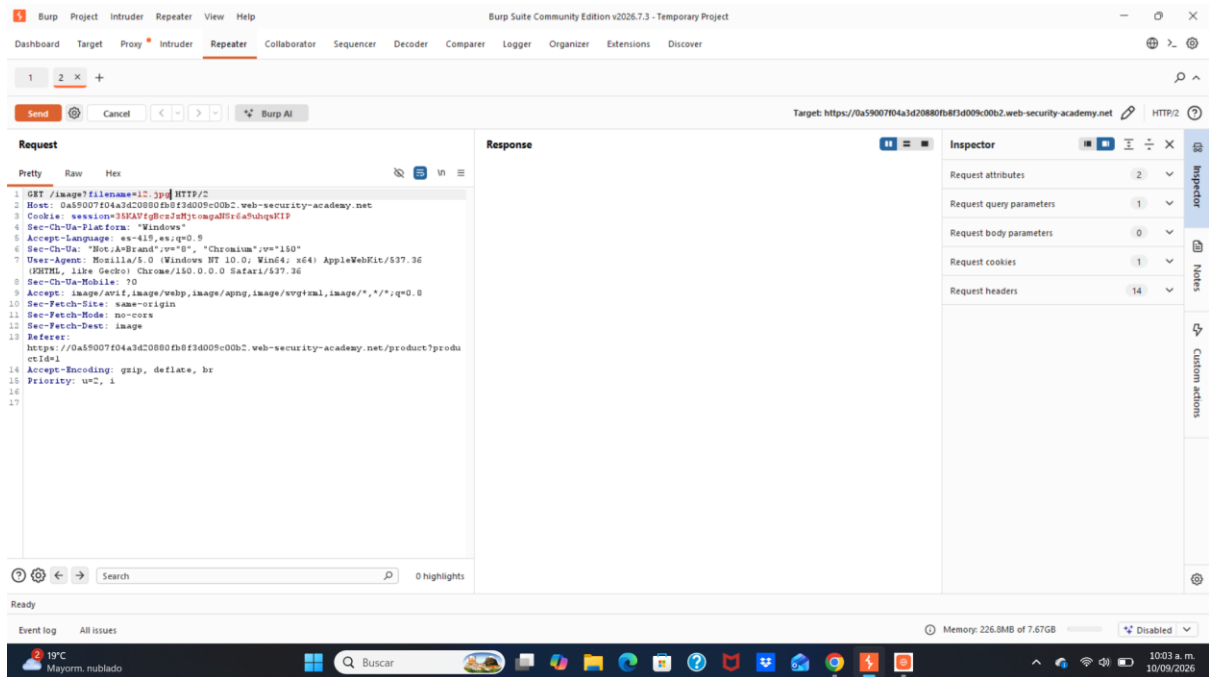
Una vez pegada la url en nuestro navegador proporcionado por BurpSuit nos aparecerá la siguiente página, que es desde donde efectuaremos nuestro ataque.



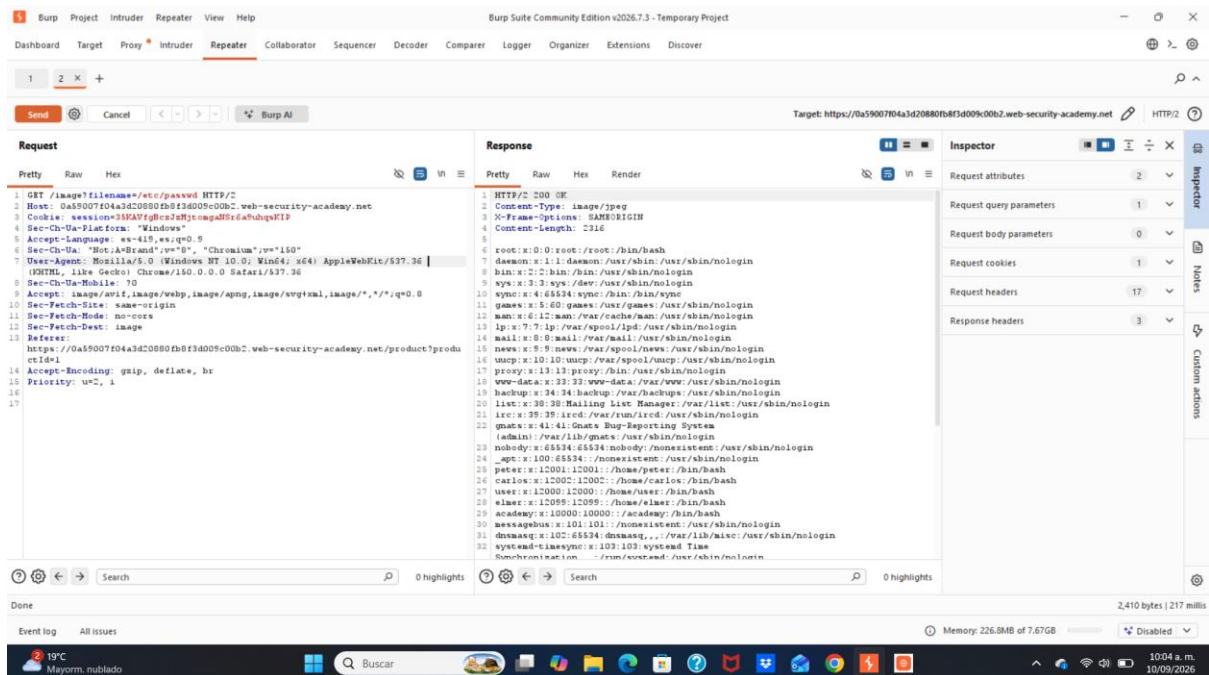
A continuación damos click en cualquiera de las imágenes, y después nos dirigimos a burpsuit donde nos iremos a la parte de index, los logs que nos parezcan le daremos a forward.



Una vez encontremos el log que nos interesa lo mandaremos al repetidor donde lo analizaremos, el log que nos interesa es el de img



Identificamos la parte de filename .jpg, que es por donde aprovecharemos la vulnerabilidad y nos meteremos.



En este caso al intentar ejecutar la dirección del path traversal simple case (../..) nos daremos cuenta de que no hay oportunidad de ingresar a los usuarios y passwords entonces probamos otra cosa la famosa “Ruta Universal”, la pagina tiene bloqueado la introducción de “../..../etc/passwd” pero no la de /etc/passwd, que al ejecutar nos arroja la información que estábamos buscando.

Posibles soluciones

1. Validación por lista blanca (Whitelist)
2. Normalización de rutas con `realpath()` y validación de prefijo
3. Uso de `basename()` como capa adicional

Conclusión

Este laboratorio revela una verdad profunda de seguridad: bloquear un patrón de ataque no equivale a resolver la vulnerabilidad en sí. Filtrar `../` solo cierra una puerta, pero la ruta absoluta es otra ventana completamente abierta. El diseño de seguridad real debe partir de "la naturaleza de la entrada del usuario": cualquier parámetro de ruta de archivo controlado por el usuario, independientemente de si contiene `../`, debe ser tratado como no confiable y pasar por una validación estricta de normalización.

Para los profesionales de seguridad, este laboratorio ejercita el pensamiento de bypass. Cuando un método de ataque es bloqueado, no se debe abandonar fácilmente, sino preguntarse: "¿Qué filtró el defensor? ¿Qué alternativa puedo usar para lograr el mismo objetivo?" La ruta absoluta es una de las técnicas de bypass más clásicas en path traversal, y entender su principio ayuda a diseñar estrategias efectivas ante defensas más complejas (como filtrado mixto, filtrado con codificación). En última instancia, este entrenamiento de pensamiento ofensivo-defensivo es el camino inevitable para avanzar de "script kiddie" a "experto en seguridad".